

CVE-2022-24439: `<gitpython::clone> 'ext::sh -c touch%/tmp/pwned'` for remote code execution #1515

Closed

#1521

 mmuehlenhoff opened on Dec 7, 2022 ...

This appeared in the CVE feed today: <https://security.snyk.io/vuln/SNYK-PYTHON-GITPYTHON-3113858>

Not sure if this was reported to you before or not, reporting it here just in case.

6

 Byron on Dec 7, 2022 Member ...

I am aware, have been informed and we can track it here. Thanks a lot for setting up this issue so timely.



 **Byron** added **acknowledged** **critical** **help wanted** on Dec 7, 2022



 **Byron** changed the title ~~CVE-2022-24439~~ CVE-2022-24439: `<gitpython::clone> 'ext::sh -c touch%/tmp/pwned'` for remote code execution on Dec 7, 2022

 ajakk on Dec 7, 2022 ...

@Byron, had Snyk or Sam Wheating (@SamWheating?) contacted you previously about this or did you learn about it independently? I'm curious given there's no reference to any upstream report in the above Snyk report.

1

 SamWheating on Dec 7, 2022 ...

I reached out to Snyk, who I believe got in touch with the maintainers.

 ajakk on Dec 7, 2022 ...

I reached out to Snyk, who I believe got in touch with the maintainers.

What makes you think that? Again, just curious given there doesn't seem to be any indication of that happening according to their report. Also, why did you go to Snyk rather than to upstream?

Byron on Dec 7, 2022

Member ...

Snyk did reach out to me by email, to my mind all this went pretty well. By publishing the issue the community can contribute a mitigation.

ajakk on Dec 7, 2022

...

Yeah, seems fine to me. It would have been nice to have an existing public report to go with the public release of the CVE so that all the people who handle CVEs (myself, and the reporter of this issue, for example) would know that the issue is already known to upstream and we don't have to spend time extracting that information via issues like this.

Thank you for the insight.

stsewd on Dec 7, 2022

Contributor ...

Looks like this same vulnerability has been reported in another git library (simple-git), <https://www.cve.org/CVERecord?id=CVE-2022-25912>.

They added an option to opt-in in to the insecure behavior

- <https://github.com/steveukx/git-js/blob/main/docs/PLUGIN-UNSAFE-ACTIONS.md#overriding-allowed-protocols>
- <https://github.com/steveukx/git-js/blob/de570acd052660bad0165347de5d2f86a494ae1b/simple-git/src/lib/plugins/block-unsafe-operations-plugin.ts>

And this should probably check for <https://www.cve.org/CVERecord?id=CVE-2022-24433> too (`git clone file:///tmp/zero123 /tmp/example-new-repo --upload-pack='touch /tmp/pwn'`)

<https://github.com/steveukx/git-js/blob/fc10fbe1cba2dedfccd8e5507b61fc979addb252/simple-git/src/lib/tasks/clone.ts#L46-L49>

♥ 1

SamWheating on Dec 7, 2022 · edited by SamWheating

Edits ...

What makes you think that? Again, just curious given there doesn't seem to be any indication of that happening according to their report. Also, why did you go to Snyk rather than to upstream?

Snyk's vulnerability program is fantastic - you can report an issue to them and they will review it, triage it, try to get in contact with the maintainers and then register the CVE if applicable. It eliminates a lot of the overhead on my end and helps to ensure that a vulnerability is handled appropriately.

<https://docs.snyk.io/more-info/disclosing-vulnerabilities/disclose-a-vulnerability-in-an-open-source-package>

I didn't have a direct line to the maintainers and I didn't want to open a public issue explaining a potentially sensitive vulnerability. In this case it sounds like Snyk was able to get in touch on my behalf and handle this disclosure responsibly.

♥ 4

jacwalte on Dec 9, 2022

Just thought I would ping to keep this issue active. This is a critical issue in my org. Can we get a status update? Is a fix expected soon?

Byron on Dec 9, 2022 · edited by Byron

Edits ▾

Member

...

~~No fix is planned~~ I don't plan to work on this directly, and this issue is triaged as 'help wanted'. *Indirectly* I am working on it by answering here and following up [on the PR](#) which might alleviate the problem.

😊 6

📄 1



 **pkfec** mentioned this [on Dec 12, 2022](#)

✓ [\[Snyk:High\] Upgrade gitpython\(due by 01/7/2023\) fecgov/fec-eregs#728](#)

40 remaining items

Load more



 **openstack-mirroring** added 2 commits that reference this issue [on Jan 10, 2023](#)

Update git submodules ...

083384d

Bump GitPython to 3.1.30 ...

614ef65



 **HebaruSan** mentioned this [on Jan 17, 2023](#)

✓ [\[Bug\] ValueError: SHA could not be resolved, git returned: b" KSP-CKAN/xKAN-meta_testing#89](#)



 **MisterGlass** mentioned this [on Jan 19, 2023](#)

✓ [gitpython version 3.1.29 has a RCE vulnerability \(CVE-2022-24439\) PyCQA/bandit#971](#)



 **netbsd-srcmastr** added a commit that references this issue [on Jan 21, 2023](#)

py-gitpython: updated to 3.1.30 ...

8b50322



 **mattip** mentioned this [on Jan 31, 2023](#)

🔗 [MAINT, BLD: Update wheel and GitPython versions. numpy/numpy#23130](#)



 **alex** mentioned this [on Feb 3, 2023](#)

 [Bump gitpython from 3.1.29 to 3.1.30 in /requirements Homebrew/brew-pip-audit#15](#)

  **complexsplit** mentioned this [on Jul 12, 2023](#)

 [updating deps. fixes https://nvd.nist.gov/vuln/detail/CVE-2022-24439 adobe/rundeck-plugin-builder#10](#)

  **EliahKagan** added 5 commits that reference this issue [on Nov 16, 2023](#)

Mark unsafe-options "allowed" tests xfail on Windows  7074aa9

Mark unsafe-options "allowed" tests xfail on Windows  96dea80

Mark unsafe-options "allowed" tests xfail on Windows  9bec3ee

Mark unsafe-options "allowed" tests xfail on Windows  5561e62

Mark unsafe-options "allowed" tests xfail on Windows  b83ce1b

  **EliahKagan** added a commit that references this issue [on Nov 24, 2023](#)

Mark unsafe-options "allowed" tests xfail on Windows  61d1fba

  **github-actions** mentioned this [on Aug 8, 2025](#)

 [Critical vulnerabilities detected in dependencies firefly-oss/sbom-tool#7](#)

[Sign up for free](#) to join this conversation on GitHub. Already have an account? [Sign in to comment](#)

Assignees

No one assigned

Labels

acknowledged

critical

help wanted

Type

No type

Projects

No projects

Milestone

No milestone

Relationships

None yet

Development

 Code with agent mode

 [Quote URLs in Repo.clone_from\(\)](#)

[gitpython-developers/GitPython](#)

 [Block insecure options and protocols by default](#)

Participants

